

Reporte de Avance de Proyecto

Diagnóstico de Arquitectura,
Seguridad y Cumplimiento

Plataforma de Gestión de
Propiedades y Reservas
integrada con Airbnb.



PRESENTADO POR EQUIPO CYBER NEXUS – GRUPO 7

Resumen Ejecutivo del Proyecto



La Empresa

Plataforma de Gestión de Propiedades y Reservas. Nuestro objetivo es simplificar y potenciar la administración de alquileres a corto plazo.



El Proyecto

Diagnóstico integral de la arquitectura, seguridad y cumplimiento. Foco en la integración con Airbnb y la optimización de procesos manuales.



La Solución

Implementación de un diagnóstico basado en tres pilares (Infraestructura, Ciberseguridad, Cumplimiento) para asegurar la escalabilidad y proteger los datos.

Los Tres Pilares del Diagnóstico

Pilar 1: Infraestructura



Mapeo de topología AWS y resiliencia (Taller 4).

Pilar 2: Ciberseguridad



Análisis de amenazas bajo modelo STRIDE (Taller 5).

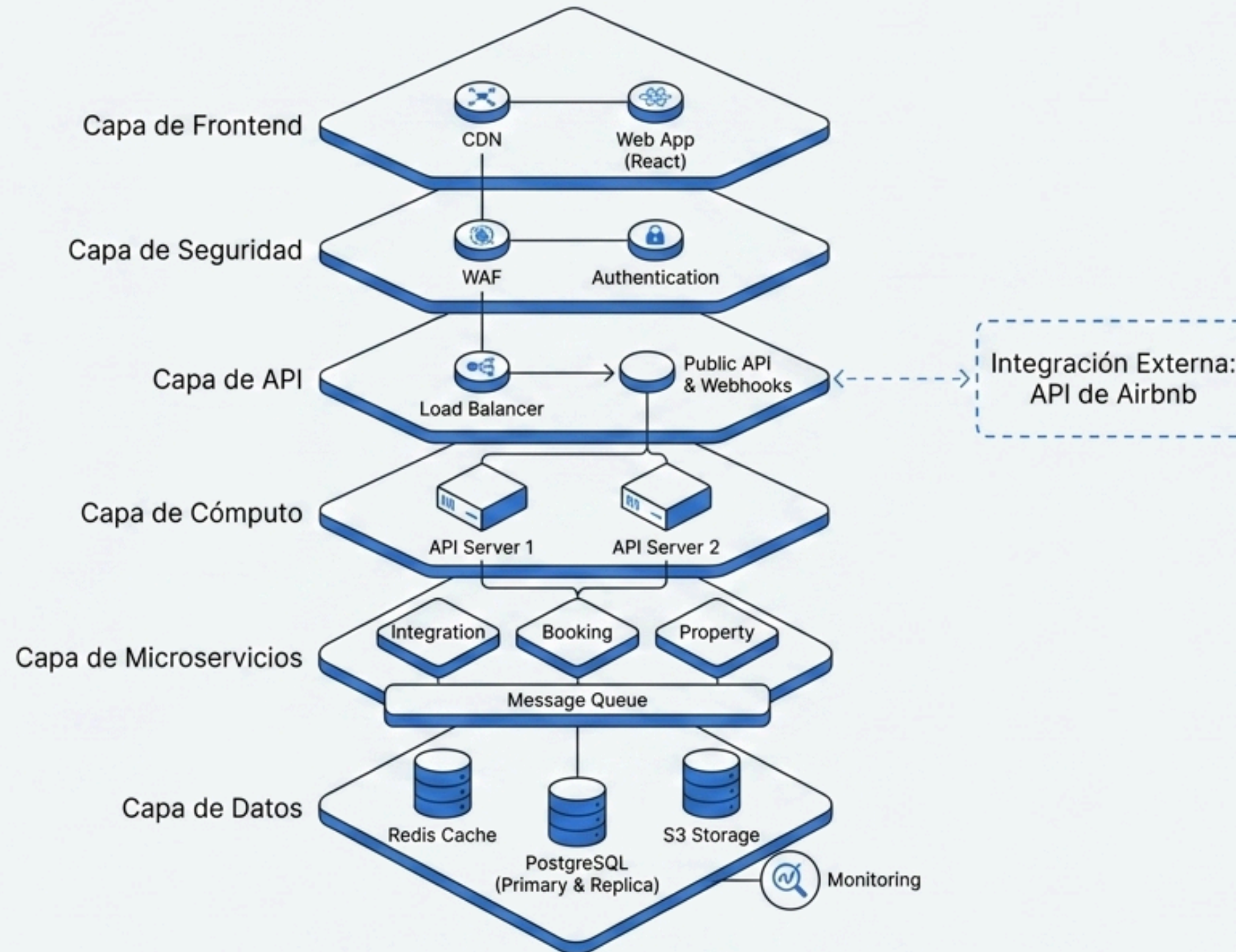
Pilar 3: Cumplimiento



Gobierno de datos y Ley 1581/ISO 27001 (Taller 6).

Estado del Proyecto: Diagnóstico integral completado. Fase de consolidación de hallazgos.

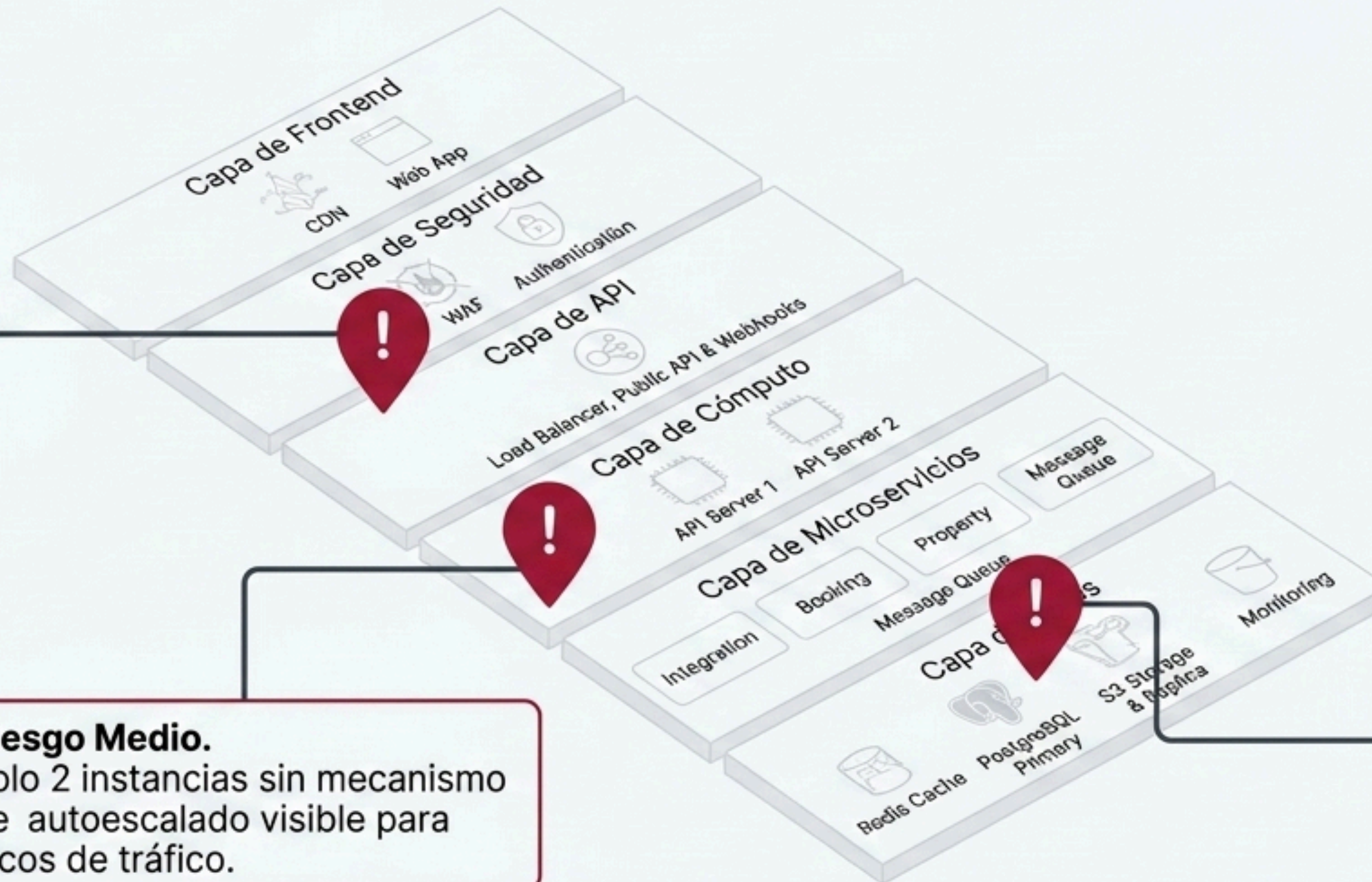
Hito 1: Mapeo de la Infraestructura en AWS Pilar 1



Diagnóstico de Infraestructura: Cuellos de Botella y SPOFs

Riesgo Alto.

Componentes únicos sin configuración Multi-AZ explícita. Una caída bloquea todo el acceso.



Riesgo Medio.

Solo 2 instancias sin mecanismo de autoescalado visible para picos de tráfico.

Riesgo Medio-Alto.

Cuello de botella de escritura. La promoción de la réplica no es instantánea.

Nota: La observabilidad (Monitoring) está limitada exclusivamente a la capa de datos, creando puntos ciegos en la API y cómputo.

Hito 2: Análisis de Ciberseguridad

Pilar 2

Componente del Sistema	Categoría STRIDE					
	S	T	R	I	D	E
Autenticación						
API de reservas						
BD de Reservas						
BD de Clientes						
Infraestructura						
Módulo Mantenimiento						
Integración Externa						

Insight Clave: El análisis revela que el riesgo crítico se concentra estructuralmente en el eje de identidad y manejo de datos personales.

Vulnerabilidades Críticas y Controles Faltantes

Spoofing en Autenticación

Robo de credenciales administrativas.

Impacto:

Acceso total a reservas y datos.

Control Recomendado:

Implementar MFA (Multi-Factor) y monitoreo de login.

Information Disclosure en BD

Exposición de base de datos de clientes.

Impacto:

Violación de privacidad y riesgo legal severo.

Control Recomendado:

Cifrado de datos en reposo y RBAC.

Denial of Service en Infraestructura

Sobrecarga masiva de tráfico.

Impacto:

Caída total del sistema (SPOF explotado).

Control Recomendado:

Configurar Rate Limiting y protección DDoS.

Hito 3: Evaluación de Cumplimiento Normativo Pilar 3

Dashboard de Madurez



Nivel de Madurez: Bajo

Brechas críticas frente a Ley 1581 e ISO 27001.



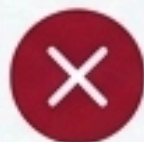
No Cumple: Consentimiento explícito para tratamiento de datos.



No Cumple: Cifrado de seguridad en reposo y tránsito.



No Cumple: Registros de auditoría (Logs).



No Cumple: Políticas de retención y eliminación.



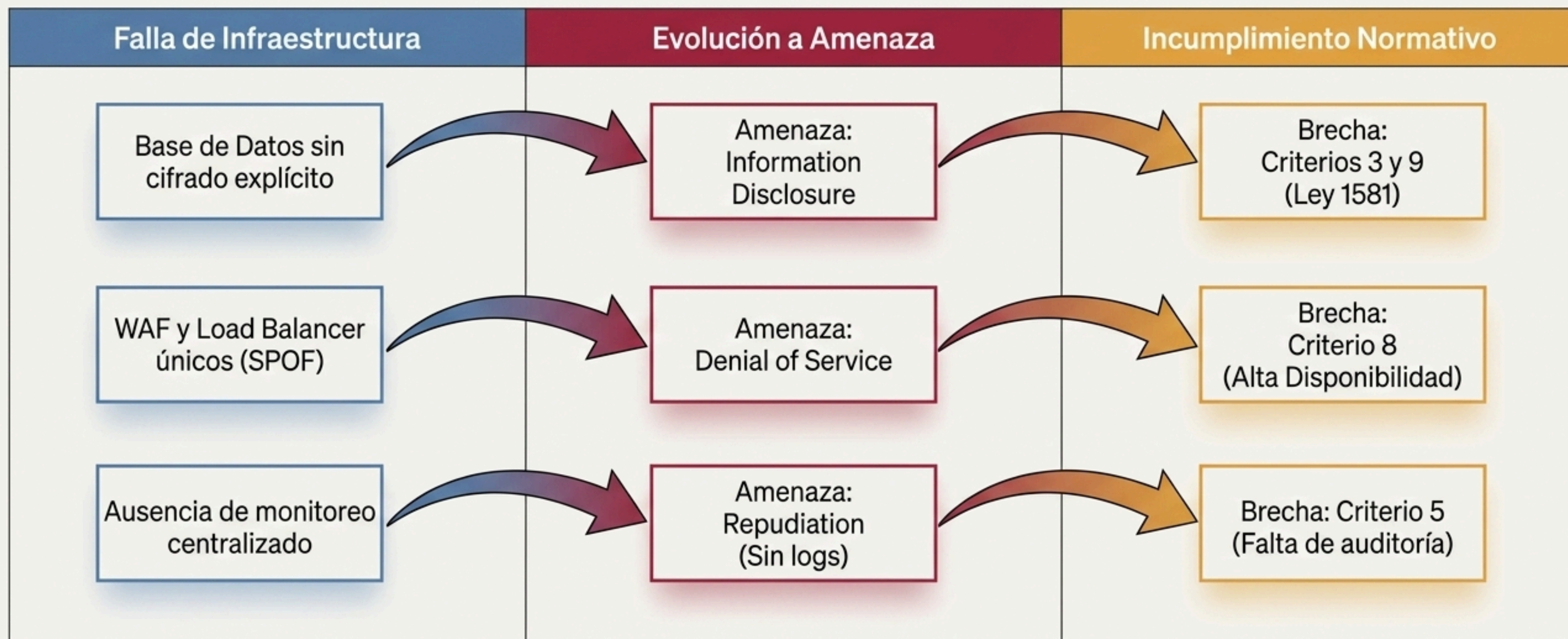
Parcial: Recolección minimizada de datos.



Parcial: Autenticación y acceso por roles (RBAC).

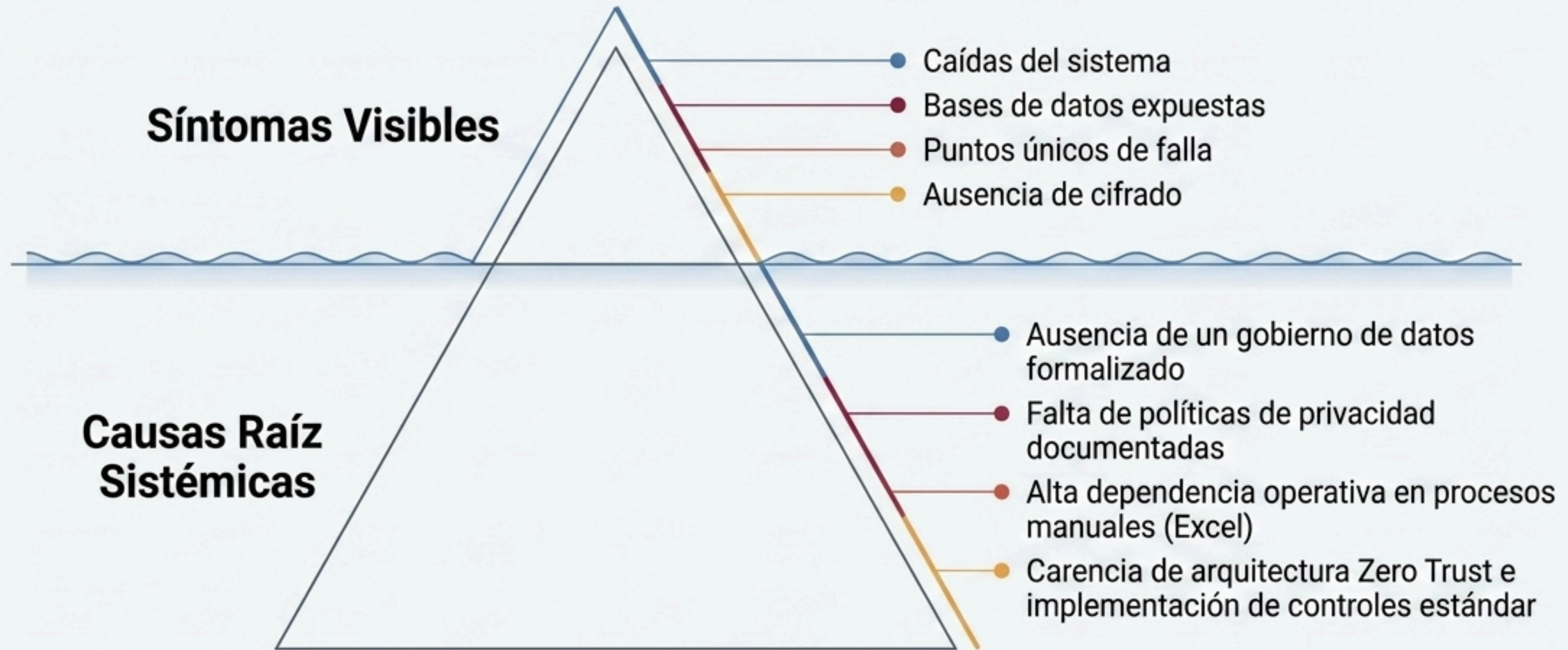
Conclusión: El sistema actual incumple principios básicos. La dependencia de procesos manuales (Excel) agrava drásticamente el riesgo de exposición legal.

La Visión Integrada: Matriz de Intersección Causal



Insight: Las vulnerabilidades no están aisladas. Una falla técnica es el detonante directo de un **incumplimiento legal**.

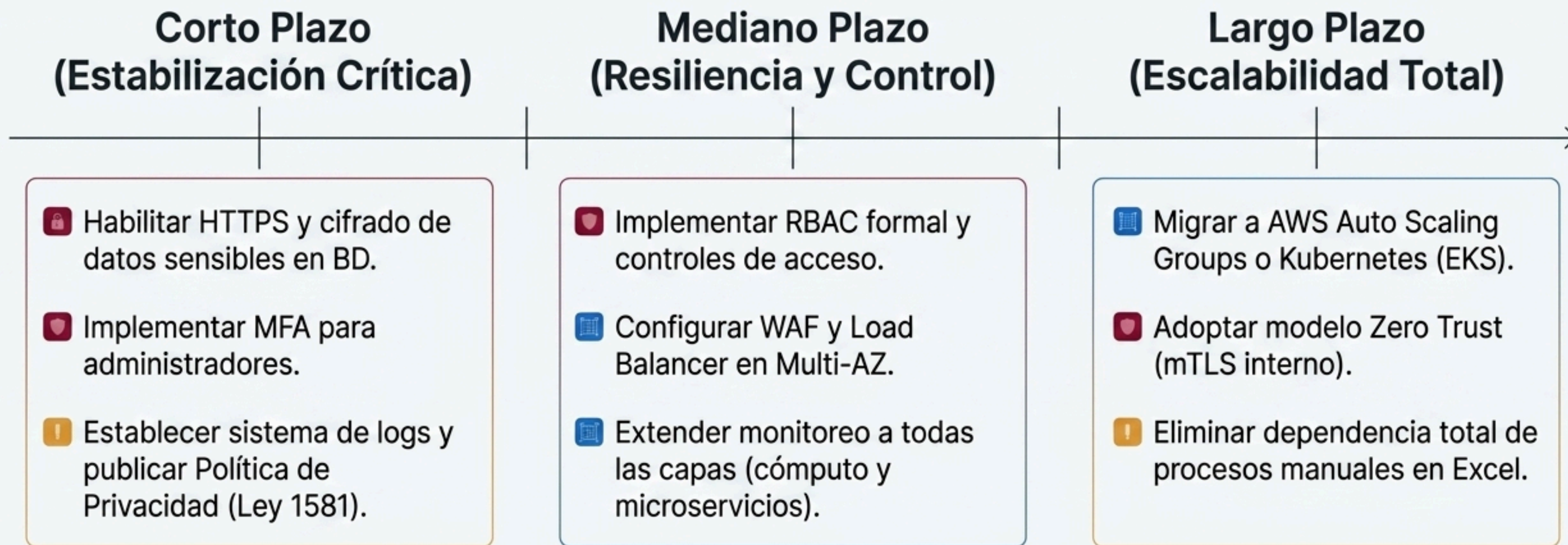
Análisis de Causa Raíz Sistémica



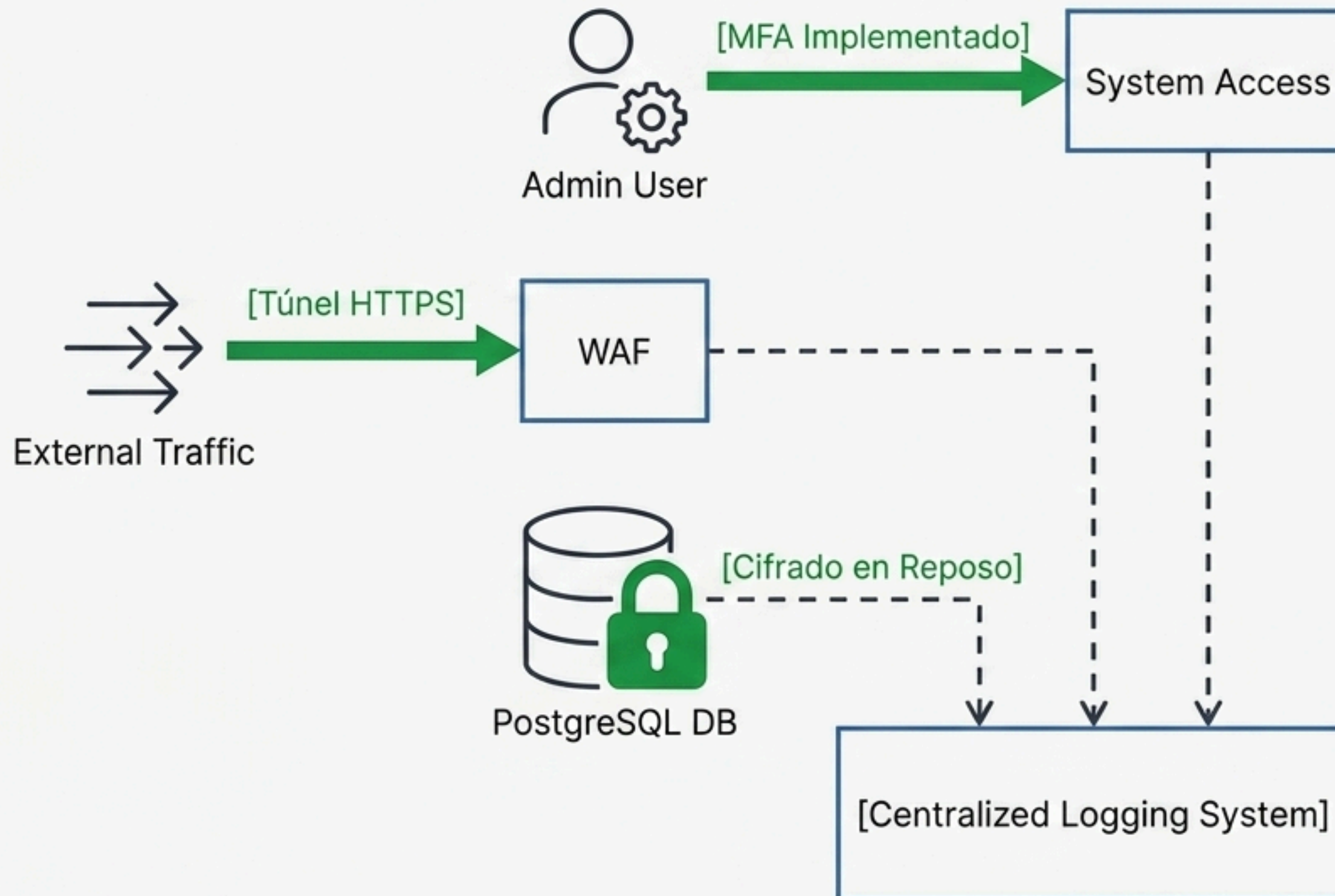
*El problema no es una limitación tecnológica de AWS;
es la falta de adopción de prácticas estándar de la industria.*

Plan de Acción Priorizado

Roadmap de Implementación y Mitigación.



Foco 1: Estabilización Inmediata (Corto Plazo)

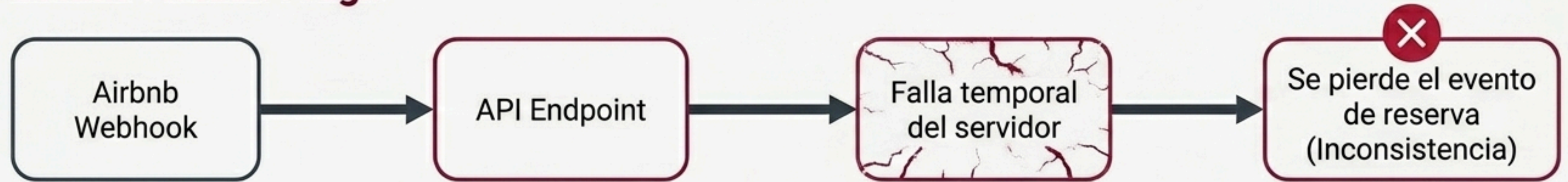


Métricas de Impacto

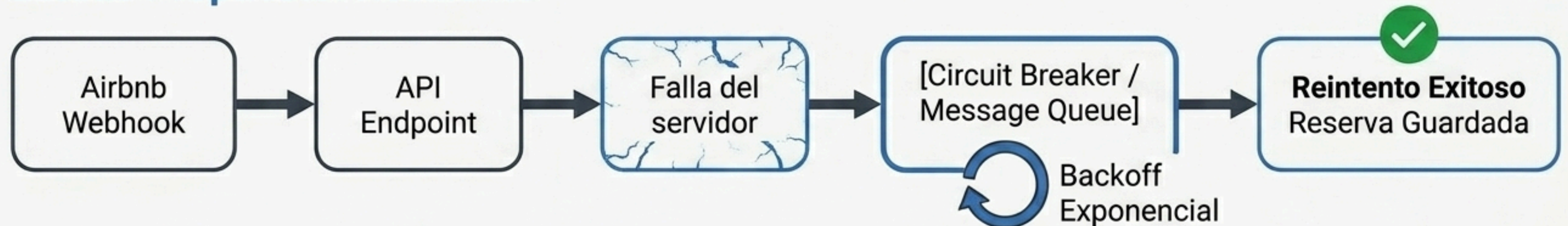
- Mitiga **3** riesgos **STRIDE** de nivel **Alto**.
- Cubre **4** brechas críticas de la **Ley 1581**.
- Esfuerzo de implementación: **Bajo/Medio** (Uso de servicios nativos de AWS).

Foco 2: Resiliencia en Integración Externa

Estado Actual: Frágil



Estado Propuesto: Resiliente



Explicación: La implementación de patrones de resiliencia previene amenazas de Tampering, asegurando la consistencia operativa sin importar picos de carga en plataformas de terceros.

Reflexiones Finales del Equipo

La arquitectura no es un silo.

Las decisiones técnicas en AWS tienen un impacto directo e inmediato en el cumplimiento normativo y la seguridad del negocio. Todo está conectado.

Los frameworks son habilitadores.

STRIDE, ISO 27001 y OWASP no son burocracia; revelan de inmediato que las vulnerabilidades nacen de la ausencia de controles estándar de la industria.

El mayor riesgo es el factor manual.

La tecnología escalable en la nube pierde todo su valor si la operación del negocio sigue dependiendo de hojas de cálculo y procesos no auditables.



La base tecnológica existe. Una evolución segura y escalable es posible mediante la implementación de controles estándar.